

Warsaw, July 18, 2023

Decision

DKN.5131.47.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended) in connection with Articles 7, 60, and 102 § 1 point 1 and § 3 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57 § 1 letters a) and h), Article 58 § 2 letter i), Article 83 § 1 – 3, Article 83 § 4 letter a) in connection with Article 24 § 1, Article 25 § 1, and Article 32 § 1 and 2, and Article 83 § 5 letter a) in connection with Article 5 § 1 letter f) and Article 5 § 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by K., President of the Personal Data Protection Office, finding that K. violated the provisions of Articles 5 § 1 letter f), Article 5 § 2, Article 24 § 1, Article 25 § 1, and Article 32 § 1 and 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as the "Regulation 2016/679", consisting of:

- 1) K.'s failure to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of data processing in the case of work performed by employees employed at X. using portable company computers, including protection against unauthorized or unlawful processing and accidental loss, destruction, or damage, which resulted in the loss (due to theft) by employee X. of his portable computer used for work purposes, which contained documents containing personal data that this employee used for business purposes,
- 2) the lack of regular testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of processed personal data, particularly in relation to the use of portable company computers, which violations result in a breach of the principle of "integrity and confidentiality" (Article 5 § 1 letter f of Regulation 2016/679) and accountability (Article 5 § 2 of Regulation 2016/679),

imposes on K. for the violation of the provisions of Articles 5 § 1 letter f), Article 5 § 2, Article 25 § 1, and Article 32 § 1 and 2 of Regulation 2016/679 an administrative fine in the amount of 15,000 Polish zlotys (in words: fifteen thousand Polish zlotys).

Justification

K., hereinafter also referred to as K. or the Administrator, (...) on May 2022, reported to the President of the Personal Data Protection Office (hereinafter also referred to as the "President of UODO") a personal data breach that occurred on (...) May 2022. The personal data breach occurred as a result of a break-in into the company car of a person holding a managerial position and the theft of their portable computer used for processing the personal data of three individuals.

As a consequence of the aforementioned personal data breach, there was a loss of confidentiality of the personal data of these individuals. The Administrator indicated that the categories of personal data that were breached included: surnames and first names, date of birth, residential or stay address, and PESEL identification number.

The President of UODO conducted an explanatory proceeding regarding the reported breach (registered under reference number [...]), and then initiated ex officio on (...) October 2022 an administrative proceeding regarding the possibility of K., as the data administrator, violating the

obligations arising from the provisions of Articles 5 § 1 letter f), Article 5 § 2, Article 24 § 1, Article 25 § 1, and Article 32 § 1 and 2 of Regulation 2016/679.

The President of UODO, as a result of the conducted explanatory proceeding regarding the reported personal data breach and the administrative proceeding, established the following factual state:

1) In a letter dated (...) May 2022, the Administrator provided the supervisory authority with explanations, indicating that "(...) the stolen computer did not have the encryption service activated, however, it had a password for the user account (...)". It was also indicated that the operating system Y. was installed on the stolen computer, while noting "(...) we currently have purchased for Z., a system that allows for the activation of B. (...)".

2) In a letter dated (...) June 2022, the Administrator indicated that the stolen computer was used outside the area of data processing. Furthermore, K. indicated that "(...) the equipment was stolen from the company car, which was also attempted to be stolen (...)".

3) In a letter dated (...) July 2022, the President of UODO requested the Administrator, among other things, to indicate whether

a) a procedure regarding the processing of personal data outside the Administrator's headquarters has been developed and implemented; if so, whether it has been updated following a personal data breach (a request was made to provide the procedure in the version applicable before the breach, as well as after the occurrence of the breach). In response to the aforementioned request, in a letter dated (...) July 2022, the Administrator indicated that "(...) the current data protection security policy contains provisions:

1) Any annotations related to the processing of data outside the area of X. must be submitted to the Data Protection Officer (DPO) at least quarterly. Information may be transmitted electronically, maintaining the document format - template no. 15 of this security policy.

2) In the case of remote work [or telework] performed by a person employed by X., the term remote work or telework based on an employment contract should be used as the area of data processing in the list of data processing locations. The above operated on the basis of telephone contact, without the application of document template no. 15 (attachment no. 1 to this letter), which will change after the breach. Processing outside the area will be more controlled, and the application of the register within the framework of attachment no. 15 will be subject to an audit at the end of this year (...)."

Regarding the training conducted for employees, the Administrator explained that "(...) in X. there is a principle that every new employee is familiarized with: (...) the most important provisions of the GDPR and the Personal Data Protection Act (...) P. (...) I. (...)". The Administrator also clarified that they are in the process of updating the software "(...) so that the possibility of launching B exists everywhere. Currently, about 61 mobile devices have encryption activated (...)." The Administrator further indicated that they plan to conduct an audit of all mobile equipment by the end of 2022 and to hold a series of teleconferences with employees of departments and organizational units on the topic of personal data protection security.

4) In response to the authority's question regarding whether the Administrator restored the personal data of individuals whose data was on the stolen laptop, the Administrator indicated that the personal data "(...) was restored using a portable memory device – an external hard drive (...)". Along with the letter dated (...) July 2022, the Administrator submitted, among other things, "Z. (...)". Detailed rules for performing backup copies were indicated in attachment no. 1 to the aforementioned regulation, which states that "(...) for the purpose of regularly performing backup copies, all organizational units receive one disk [(...) with a capacity of 1 TB], secured with a password [...] (...) in the framework of performing backup copies, all data whose loss could have severe consequences for the functioning of the unit must be included, [including: reports], as well as materials related to promotional activities such as: photos and videos. The importance of the data and the decision to create a backup copy, as well as the scope of the data, is determined by the Head of the organizational unit (...) Each unit is obliged to regularly perform backup copies, at least once a month, by the 5th day of each month and additionally whenever necessary and at the discretion of the head of the unit (...) As part of verifying the

correctness of backup copies performed in organizational units, random checks may be carried out by employees of B. (...) Every person with access to the disk, and thus to the personal data stored on it, is responsible for its security. Access for employees is determined by the head of the unit. What is included in the internal document (...).” In § 6 of the document “Principles (...)” it was indicated that according to the adopted data protection security policy, disks may only be used within the organizational unit (section 1). An employee is allowed to take the storage device outside the area of the organizational unit only in the case of the necessity to deliver the equipment to B., after previously notifying the IT team or DPO (section 2). The disk, along with the transfer protocol, must be stored in a locked cabinet, in an appropriate room, to which the institution's beneficiary does not have access (section 3). For taking the disk outside the processing area without a justified purpose and without notifying the IT team or DPO, disciplinary consequences may be imposed (section 4).

5) In response to the supervisory authority's request contained in the letter dated (...) July 2022 for the submission of a risk analysis functioning before the personal data breach and performed after the breach, the Administrator, in a letter dated (...) July 2022, indicated “(...) X. submits: 1) A risk analysis for the processing of personal data outside the processing area for X. - attachment no. 3 to this letter, performed according to the methodology - attachment no. 4. 2) A table allowing the determination of the severity of the breach according to the methodology of the assessment of the severity of the breach according to the European Union Agency for Cybersecurity (ENISA), [attachment no. 5]. (...)” By attaching a copy of the risk analysis “CARD [...] (...)”, the Administrator did not indicate the date on which the risk analysis was conducted.

6) The Administrator further explained in the letter dated (...) July 2022 that “(...) the breach - [the theft of a laptop], affected senior management, which often performs activities, due to their official duties, while on business trips. In light of this fact, appropriate provisions were added in the revised content of the personal data security policy in X. (...) [attachment 22 to the revised security policy (...)] (...)”. In attachment no. 22 of the security policy (...), it was indicated that “(...) the senior management of X. is particularly obliged to: - progressively raise the level of awareness in the area of information security, including personal data protection, - regularly, [at least once a quarter],

****Discussion of Management Strategies (...),****

including personal data protection with the Data Protection Officer (DPO) and the Information Security Officer (ISO), -

the use of secured mobile work equipment, such as: laptops, tablets, phones. All storage devices used by senior management must have B activated. An exception may be made for phones, provided that they do not store personal data significant to the company and associated with a high risk of harm to the individuals concerned (...).

7) In response to the initiation of administrative proceedings, in a letter dated (...) December 2022, the Administrator informed the supervisory authority that it had taken actions “(...) aimed at enhancing protection against such incidents in the future, namely: it implemented the activation of B on mobile computers such as laptops, which have the appropriate operating system (...) is preparing a request to the superior unit [...] for technical support, i.e., the possibility of providing better quality laptops that would have the capability to activate B and geolocation (...) updated the security policies [as mentioned in the letter to the President of the UODO dated (...) July this year], and additionally informed employees X. about the prohibition of taking laptops outside the processing area without the explicit consent of the Unit Manager and the Data Administrator, i.e., K. (...) took actions aimed at activating geolocation - the planned activation time on all laptops with the appropriate programming is June 2023 (...)”. Attached to the explanations was a statement from an employee of the Administrator, holding the position of IT and Telecommunications Specialist, dated (...) October 2022, which indicates that from (...) May 2022 to (...) June 2022 “(...) on electronic devices such as laptops belonging to X., encryption of type B was activated (...)”. Furthermore, along with the aforementioned letter, the Administrator attached, among others: “Analysis No. 1 (...)”, “Analysis No. 2 (...)” - The Administrator did not indicate the date on which the aforementioned risk analyses were conducted.

8) In order to obtain unequivocal explanations regarding the date of the risk analysis conducted, the President of the UODO once again addressed the Administrator on this matter. In a letter dated (...)

March 2023, the President of the UODO requested: a) to indicate the date of the risk analysis conducted before the occurrence of the personal data breach (this document is attached as Annex No. 4 to the Administrator's letter dated (...) December 2022) and the date of the risk analysis conducted "after considering the control mechanisms" (this document is attached as Annex No. 5 to the Administrator's letter dated (...) December 2022), b) to send and indicate the date of the risk analysis conducted before the risk analysis that constitutes Annex No. 4 to the Administrator's letter dated (...) December 2022 (if such analysis was not conducted, the reason for its non-execution was requested). In response to the aforementioned questions from the supervisory authority, the Administrator once again did not provide a clear answer, indicating in a letter dated (...) March 2023 that "(...) Annex No. 4 and Annex No. 3 were additionally prepared in the form of separate analyses in separate files at the request of representatives of the GIODO expressed as we understood during the visit to the UODO on (...) October 2022. Both analyses in their original version were in one file, which was submitted in the letter dated (...).07.2022. The file itself has a creation date of: (...).08.2012 [PrtSC - Annex No. 1 to this letter.]. This results from the fact that the analysis processes were conducted/created on modified files from the previous employee who held a position related to internal control. The first analysis was conducted around mid-2020, after which the file was verified at the time of the breach. Changes were made, among others, in the wording regarding the removal of mobile devices such as laptops/tablets containing personal data without consent (...) Previously, it was worded as the removal of data storage devices such as laptops [...]. The risk analysis pertains to actions and is an active file (...)". Additionally, in the letter dated (...) March 2023, the Administrator indicated that "(...) (...)03.2023 the procedure for implementing the service package from company M. was completed, allowing, using service A., all computers to be registered in the organization. This allows for checking the activity and IP login numbers of specific employees, as well as monitoring Internet connections in the event of a laptop loss (...)". The supervisory authority assessed the evidence material in terms of its credibility and evidential value. The President of the UODO considered the vast majority of the evidence submitted by the Administrator to be credible. This is supported by the fact that the key explanations provided by the Administrator are logical, coherent, and correlate with the entirety of the evidence material. However, it cannot be overlooked that the Administrator, when providing explanations, submitted documents (evidence to confirm them) from which it was not clear on what date they were created. This resulted in the need for the authority to obtain additional explanations to accurately determine and investigate the factual state. This does not mean that the President of the UODO considered any of the key evidence for the resolution to be unreliable and lacking evidential value. However, it has a significant impact on the assessment of the degree of cooperation of the Administrator with the President of the UODO in order to eliminate the breach and mitigate its potential negative effects. A detailed analysis of individual documents provided by the Administrator (in case of doubts on the part of the authority regarding their credibility and evidential value) was conducted in the further part of the justification.

In this factual state, after reviewing all the evidence gathered in the case, the President...
The Office for Personal Data Protection has considered the following.

Firstly, it should be pointed out that in this matter, the data controller is K., as – according to Article 4 point 7) of Regulation 2016/679 – "controller" means a natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the controller may also be designated by Union law or the law of a Member State or specific criteria for its designation may be laid down. (...)

Confirmation of the above is also provided by the document "Policy (...)" submitted to the case files of this proceeding. According to § 3 point 5 of the aforementioned document, the Personal Data Controller (ADO) means K. In the aforementioned document, it was indicated, among other things, "(...) §6 OBLIGATIONS OF PERSONS RESPONSIBLE FOR PERSONAL DATA PROTECTION 1. Obligations of the Personal Data Controller. a. Taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity of the threat, the ADO implements appropriate organizational

and technical measures to ensure that processing is performed in accordance with the GDPR and to be able to demonstrate this unequivocally. These measures are reviewed and updated as necessary.

b. In accordance with Article 37(1)(a) of the GDPR, the ADO appoints a Data Protection Officer (IOD);

c. The ADO appoints an Information Systems Administrator (ASI), who is responsible for the proper functioning of information systems in X.

d. The ADO authorizes persons indicated by the heads of organizational units to process personal data. A template of the authorization constitutes Annex No. 3 to this Protection Policy.

e. The ADO performs a supervisory role regarding the principles of proper processing of personal data in accordance with the requirements and recommendations of the GDPR (...). The above unequivocally determines that the data controller in this matter is K.

It should be noted that the President of the UODO, when addressing correspondence to the Controller, referred to them as W., as this was how the Controller indicated the full name of the controller in the data breach notification form dated (...) May 2022, which was submitted by them to the supervisory authority. Given that the Controller received correspondence from the President of the UODO and responded to it to the supervisory authority, and that the aforementioned discrepancy was not corrected by the Controller at any stage of the administrative proceedings, it should be concluded that the above-described inconsistency in the name of the controller did not affect the course of the administrative proceedings. Acknowledging that there was an obvious clerical error in the data breach notification dated (...) May 2022, in order to eliminate any doubts, the supervisory authority clarified the issue of the name of the controller in this decision, indicating that the data controller is K.

According to Article 34 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781) - hereinafter referred to as the Act of May 10, 2018, the President of the UODO is the competent authority in matters of data protection and the supervisory authority within the meaning of Regulation 2016/679. Pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority on its territory monitors and enforces the application of this regulation and conducts proceedings regarding violations of this regulation, including based on information received from another supervisory authority or another public authority. Article 5 of Regulation 2016/679 formulates principles regarding the processing of personal data that must be respected by all controllers, i.e., entities that determine the purposes and means of processing personal data, either alone or jointly with others. According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("confidentiality and integrity"). Furthermore, according to Article 5(2) of Regulation 2016/679, the controller is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance ("accountability"). The specification of the confidentiality principle referred to in Article 5(1)(f) of Regulation 2016/679 is provided by further provisions of this legal act. According to Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity, the controller implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate this. These measures are reviewed and updated as necessary.

Pursuant to Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity resulting from processing, the controller – both when determining the means of processing and during the processing itself – implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide the necessary safeguards for processing to meet the requirements of this regulation and protect the rights of data subjects.

From the content of Article 32(1) of Regulation 2016/679...

It follows that the administrator is obliged to apply technical and organizational measures

corresponding to the risk of infringement of the rights and freedoms of individuals, taking into account the varying likelihood and severity of the threat. The provision specifies that when deciding on technical and organizational measures, one must consider the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of individuals with varying likelihood and severity. From the cited provision, it follows that determining appropriate technical and organizational measures is a two-step process.

Firstly, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to restore the availability of personal data and access to it quickly in the event of a physical or technical incident, and regular testing, measuring, and evaluating the effectiveness of the technical and organizational measures intended to ensure the security of processing.

According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the administrator takes into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed.

As indicated in Article 24(1) of Regulation 2016/679, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of individuals with varying likelihood and severity, are factors that the administrator is obliged to consider in the process of building a data protection system, particularly in light of the other obligations specified in Article 25(1), Article 32(1), or Article 32(2) of Regulation 2016/679. The indicated provisions specify the principle of confidentiality defined in Article 5(1)(f) of Regulation 2016/679, and adherence to this principle is necessary for the proper implementation of the accountability principle arising from Article 5(2) of Regulation 2016/679.

One of the legal bases for the protection of personal data introduced by Regulation 2016/679 is the obligation to ensure the security of processed data, specified, among others, in Article 32(1) of Regulation 2016/679. This provision introduces a risk-based approach, simultaneously indicating the criteria based on which the administrator should select appropriate technical and organizational measures to ensure a level of security corresponding to that risk. Alongside the risk of infringement of the rights or freedoms of individuals, one must also consider the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing.

For the proper fulfillment of the obligations arising from the aforementioned provisions of Regulation 2016/679, the administrator should first conduct a risk analysis and based on it, determine and implement adequate measures to ensure security in the process of processing personal data. In cases where the administrator has anticipated the possibility of using computer equipment (on which personal data is processed) outside of their premises, the analysis should indicate potential risks arising from the possibility of its use in connection with performing work outside the organization's premises. Consequently, the analysis should foresee appropriate security measures to minimize the risk of a personal data breach.

In the context of this case, it should be noted that by allowing the possibility of processing personal data using portable work computers outside the premises of their organization, based on a properly conducted risk analysis, the administrator should identify threats to the personal data processed in this manner, and then determine and implement appropriate technical and organizational measures to ensure the security of this data, as well as regularly check the effectiveness of these measures, in accordance with the requirements arising from Articles 32(1) and (2) of Regulation 2016/679.

In the discussed case, conducting such an analysis was particularly important due to the specificity of

the work performed in a position where work was expected to be carried out on a business trip. The circumstances mentioned above, due to the necessity of adopting solutions regarding the processing of personal data, should lead to the undertaking of a series of additional actions to ensure the security of personal data, and the starting point for determining these should be, which must be emphasized again, conducting a risk analysis that assumes the possibility of loss of access (e.g., as a result of theft or loss) to the computer equipment used for processing personal data by employees outside the administrator's organization, and as a result, the breach of confidentiality of the data contained on that equipment. It should also be noted that the obligation to implement appropriate technical and organizational measures to provide the necessary safeguards for processing, given the adopted method of processing personal data, also arises directly from Article 25(1) of Regulation 2016/679. This provision requires the data administrator to consider data protection, particularly at the design phase.

what it means is that the Administrator, by allowing employees to use laptops outside the Administrator's organization, should already at this stage define (and implement) effective security measures. Regulation 2016/679 introduced an approach in which risk management is the foundation of actions related to the protection of personal data and is characterized as a continuous process. Data processors are obliged not only to ensure compliance with the guidelines of the aforementioned regulation through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards. This means that it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk, as well as take into account the nature of the organization and the mechanisms used for processing personal data. The Administrator must conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk. The consequence of such an orientation is the abandonment of lists of requirements regarding security imposed by the legislator in favor of independently selecting safeguards based on a threat analysis. Administrators are not provided with specific security measures and procedures.

In light of the above, it should be noted that the risk analysis conducted by the data administrator should be documented and justified primarily based on the determination of the factual state existing at the time of its conduct. It is necessary to take into account, in particular, the characteristics of the processes occurring, assets, vulnerabilities, threats, and existing safeguards within the data processing processes. It is also essential not to overlook the scope and nature of the personal data processed during the activities carried out by the data administrator, as the potential negative consequences for the individual in the event of a breach of their personal data protection will depend precisely on the scope and nature of the disclosed data.

The term "assets" is used to indicate everything that constitutes value for the data administrator. Certain assets will have a higher value than others, and from this perspective, they should be assessed and secured. The interconnections of the existing assets are also very important; for example, the confidentiality of assets (personal data) will depend on the type and manner of processing that data. Determining the value of assets is necessary to estimate the consequences of a potential incident (breach of personal data protection). It is obvious that a wide range of personal data or the processing of personal data referred to in Articles 9 or 10 of Regulation 2016/679 may cause far-reaching negative consequences for the individuals concerned in the event of a breach of personal data protection, so they should be assessed as high-value assets, and consequently, the degree of their protection should be appropriately high.

Determining the existing or applied safeguards is necessary, among other things, to avoid duplication. It is also imperative to verify the effectiveness of these safeguards, as the existence of an untested safeguard may first eliminate its value, and secondly, may create a false sense of security and may result in the omission (non-detection) of a critical vulnerability, which, if exploited, could lead to very negative consequences, including, in particular, a breach of personal data protection. Vulnerability is

commonly defined as a weakness or gap in security that, if exploited by a given threat, can disrupt operations and may also lead to incidents or breaches of personal data protection. Identifying threats involves determining what threats may arise and from what direction (cause).

One method of conducting a risk analysis is, for example, to define the level of risk as the product of the probability and consequences of a given incident occurring. A risk matrix is typically used, which allows for a visual representation of risk levels, presenting the risk levels for which the organization defines appropriate actions. For the risk analysis to be conducted properly, threats that may occur in the data processing processes should be defined for each of the assets. Taking into account, in particular, the scope of personal data processed by the Administrator using a stolen laptop, in order to properly fulfill the obligations imposed by the aforementioned provisions of Regulation 2016/679, the Administrator was obliged to take actions ensuring an appropriate level of data protection by implementing appropriate technical and organizational measures, as well as actions aimed at optimally securing and configuring the resources, tools, and devices (including computer equipment) used through regular testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of data processing in the form of security tests concerning the IT infrastructure and applications. The nature and type of these actions should result from the conducted risk analysis, in which vulnerabilities related to the utilized resources should be identified, and the resulting threats, and then determine appropriate security measures. In this vein, the Administrative Court in Warsaw expressed itself in its judgment of May 13, 2021, case no. II SA/Wa 2129/20, where it stated that "the data administrator should therefore conduct a risk analysis and assess what threats they are dealing with."

It should be emphasized that risk management (conducting a risk analysis and implementing appropriate safeguards based on it) is one of the fundamental elements of the personal data protection system and, as indicated by the aforementioned judgment of the Provincial Administrative Court in Warsaw, is a continuous process. Therefore, there should be periodic verification of both the adequacy and effectiveness of the safeguards applied, in accordance with the requirement set out in Article 32(1)(d) of Regulation 2016/679.

The data administrator should therefore regularly test, measure, and assess the effectiveness of the technical and organizational measures designed to ensure the security of processing. New risks or threats may materialize or be revealed spontaneously, in a manner completely independent of the administrator, and this is a fact that should also be taken into account both when building the personal data protection system and during its implementation. This, in turn, defines the necessity of conducting regular verification of the entire personal data protection system in terms of both the adequacy and effectiveness of the implemented organizational and technical solutions, within the framework of both the risk analysis conducted and regular testing, measuring, and assessing the effectiveness of the technical and organizational measures designed to ensure the security of processing.

It should also be emphasized that the assessment of the probability of a given event occurring should not be based solely on the frequency of occurrences in a given organization, as the fact that a given event has not occurred in the past does not mean that it cannot occur in the future.

In this context, it should be noted that the Provincial Administrative Court in Warsaw, in its judgment of August 26, 2020, case no. II SA/Wa 2826/19, stated that "(...) activities of a technical-organizational nature fall within the competence of the personal data administrator, but they cannot be selected in a completely arbitrary and voluntary manner, without taking into account the level of risk and the nature of the protected personal data."

In this case, the Administrator was repeatedly called upon by the supervisory authority to submit a risk analysis conducted prior to the occurrence of the personal data breach, as well as one conducted after its occurrence. In response to the letter from the supervisory authority dated (...) July 2022, in which the President of the UODO requested the submission of the risk analysis that was in place before the personal data breach and one conducted after the breach, the Administrator – in a letter dated (...) July 2022 – provided a document from which it was not clear when the submitted analysis was conducted

(see point 5 of the factual justification).

In the file submitted with the aforementioned letter, saved in .xls format and named "Attachment (...)", in the sheet named "Card (...)", the type of data processing was specified as "Processing of personal data outside the area using data carriers such as laptop/tablet/external hard drive (data excluding Article 9)" and "Processing of personal data outside the area using data carriers such as laptop/tablet/external hard drive (data including Article 9)." Within the aforementioned types of processing – in the section of the "Card (...)" designated as "Inherent risk" – the Administrator identified threats, including those defined as "loss/theft of equipment with no encryption activated," determining the risk level as high, while indicating that: "Unacceptable risk level – action may be postponed, requires constant monitoring," and as "Recommendations/Guidelines/Control mechanisms," indicated: "securing all mobile devices with encryption systems, e.g., B."

In the section of the "Card (...)" designated as "Residual risk (taking into account control mechanisms)," the Administrator identified the same types of data processing and threats as described above, with the difference that – in the case of the key threats relevant to this matter, i.e., loss/theft of equipment with no encryption activated – the Administrator adjusted the risk level, indicating that it is low, and that the level of this risk is acceptable.

The above-discussed risk analysis was again submitted to the supervisory authority along with a letter dated (...) December 2022 in the form of attachments (see point 7 of the factual justification) with the difference that it was presented in the form of two files saved in .xls format. In both the case of the risk analysis submitted with the letter dated (...) July 2022 and in the case of the one submitted with the letter dated (...) December 2022, the Administrator did not indicate the dates of their conduct. Furthermore, the terms used by the Administrator, "inherent risk" and "residual risk," do not allow for a clear assessment of whether the Administrator conducted a risk analysis prior to the occurrence of the breach.

It should be noted at this point that the form of the submitted analysis is illegible and some of the entries contained in it are incomprehensible. Although the Administrator independently decides on the form and content of the conducted analysis, they should be able, in accordance with the principle of accountability (Article 5(2) of Regulation 2016/679), to demonstrate that such an analysis was conducted properly, i.e., that it constitutes an appropriate tool for the effective implementation and subsequent monitoring of the measures.

guaranteeing safety in the process of processing personal data. First and foremost, it should be noted that the presented risk analysis does not indicate the reasons for mitigation – a key issue in this case – of the risk, i.e., the submitted analysis shows that the Administrator has reduced the risk of the threat of "loss/theft of equipment in the absence of activated ", indicating that the risk is acceptable (whereas – according to the previous version of the risk analysis – it was deemed unacceptable). The lack of indication of the dates of the aforementioned analyses prompted the supervisory authority to send another letter requesting the indication of missing information necessary for an accurate and complete determination of the factual state. In the letter dated (...) March 2023, the Administrator once again provided evasive answers, limiting himself to stating that "(...) the first analysis was conducted around mid-2020, after which the file was verified at the time of the occurrence of the breach. A change was made, among other things, in the formulation regarding the removal of mobile devices such as laptops/tablets containing personal data without the consent of O. (...)"

It should also be pointed out that the President of the UODO did not recognize the credibility of the evidence: "Attachment No. 1 – PrtSC Details of file creation", which was delivered by the Administrator along with the letter dated (...) March 2023. In the Administrator's opinion, it would follow from the aforementioned attachment that "(...) both analyses in their original version were in one file, which was submitted in the letter dated (...).07.2022. The file itself has a creation date of: (...).08.2012 (...)" The information contained in the properties of the file saved in .xls format, currently named "Attachment (...)", stating that this file was created in (...) August 2012 does not prove that the risk analysis itself was created on that day. The content of the file in .xls format with the current name "Attachment (...)" could have undergone multiple changes (i.e., the said file could contain any content provided that the

saving of this data could have been done in .xls format), moreover, the name of this file could also have been changed multiple times. In light of the above, the attached screenshot indicating the properties of the .xls file with the current name "Attachment (...)" has no evidential value. Furthermore, considering the continuous avoidance by the Administrator of providing a clear answer as to when the risk analysis was actually conducted, the provision of such "evidence" only indicates a lack of good cooperation between the Administrator and the supervisory authority.

Regardless of the above, the President of the UODO does not have grounds to deem the Administrator's explanations, in which he states that he conducted a risk analysis before the occurrence of the breach, as unreliable. The Administrator explained that "(...) the first analysis was conducted around mid-2020, after which the file was verified at the time of the occurrence of the breach (...)". The submitted risk analysis clearly indicates that before the occurrence of the breach, the Administrator identified a threat that ultimately materialized and constitutes the direct cause of the occurrence of the personal data breach. Moreover, the Administrator himself also defined the level of this risk, indicated that it is unacceptable ("Unacceptable risk level – action may be postponed, requires constant monitoring") and specified "Recommendations / Guidelines / Control mechanisms" indicating that it is necessary to implement "security for all mobile devices using encryption systems, e.g., B."

As already indicated above, in the factual state of the case in question, the risk concerned the threat related to the theft of portable computer equipment used for business purposes outside the Administrator's organization. As established, the aforementioned computer was secured against unauthorized access only by means of a password. At this point, it should be noted that in relation to portable computers taken outside the Administrator's organization, due to the associated threats, in order to counteract potential consequences of a breach and to prevent the loss of confidentiality of personal data contained on such a device, the administrator, in accordance with the aforementioned provisions of Regulation 2016/679, is obliged to implement additional security measures in the form of, for example, encrypting the hard drives of the computer. The specification of these additional security measures should occur as a result of a conducted risk analysis, following a proper identification of threats to personal data processed using portable computers used outside the Administrator's organization.

As follows from the risk analysis presented by the Administrator, conducted (as he claims) before the occurrence of the breach, the Administrator was aware of the risks associated with the loss of computer equipment taken outside his organization (this issue has already been discussed in detail above). It should be emphasized once again that the Administrator assessed this risk as unacceptable and determined, within the framework of the risk management approach, the security measures that should be implemented to mitigate it. Among the mentioned security measures aimed at reducing the level of risk, the Administrator indicated that it is necessary to implement "security for all mobile devices using encryption systems, e.g., B." It should be emphasized that the obligation to implement data carrier encryption also arises from Article 32(1)(a) of Regulation 2016/679.

In the opinion of the President of the UODO, from the moment of developing the risk analysis (i.e., as the Administrator himself explains – from "mid-2020") to the date of the determination of the personal data breach (the breach was determined on [...] May 2022), sufficiently long time has passed for the implementation of mitigating mechanisms – an unacceptable level as determined by the Administrator himself – of the risk.

****Risks for Operations Related to the Processing of Personal Data Outside the Headquarters of the Administrator's Organization Using Data Carriers Such as Laptop / Tablet / External Drive in Connection with the Possibility of Loss or Theft of Equipment in the Absence of Activated for Encryption.****

The Administrator, despite correctly identifying the threats to personal data processed using computers taken outside his organization in the risk analysis (conducted in 2020), and also correctly determining the level of risk for the aforementioned data and defining the method of risk management by indicating the safeguards that should be applied to reduce this risk, did not take any actions to

actually eliminate or limit this risk to an acceptable level. The result of the Administrator's inaction in this regard was the materialization of the identified threat in the form of the theft of a work computer containing personal data, on which appropriate safeguards were not applied to protect this data, resulting in a breach of its confidentiality.

As indicated by the Provincial Administrative Court in Warsaw in the justification of the judgment of August 26, 2020, case no. II SA/Wa 2826/19, "This provision [Article 32 of Regulation 2016/679] does not require the data administrator to implement any technical and organizational measures that are to constitute means of protection for personal data, but requires the implementation of adequate measures. Such adequacy should be assessed in terms of the manner and purpose for which personal data is processed, but also the risk associated with the processing of this personal data, which may be characterized by varying degrees.", and also "The adopted measures must be effective; in specific cases, some measures will have to mitigate low risk, while others must mitigate high risk. It is important that all measures (and each one individually) are adequate and proportional to the level of risk."

Despite being called upon by the supervisory authority to indicate whether a procedure regarding the processing of personal data outside the administrator's headquarters has been developed and implemented, and if so, whether it has been updated after the breach of personal data protection (a request was made to provide the procedure in the version applicable before the breach, as well as after the occurrence of the breach), the Administrator limited himself to sending the amended "Policy (...)". Consequently, the President of the Personal Data Protection Office (UODO) – despite attempting to obtain clarifications to establish the detailed principles that the Administrator defined in the event of allowing the processing of personal data outside his organization's headquarters – was unable to assess whether the Administrator complied with his own procedures in this regard. However, the inability to conduct such an assessment is of secondary importance in the sense that by not submitting a document regulating the issue of processing personal data using portable computer equipment outside the headquarters of his organization, the Administrator did not demonstrate – in accordance with the principle of accountability (Article 5(2) of Regulation 2016/679) – that the principles defined by him (applicable before the occurrence of the personal data breach) provided for the implementation of appropriate technical measures during the processing of personal data, so that this processing would be carried out in accordance with Regulation 2016/679.

As a consequence, the President of the UODO is unable to assess whether and how the Administrator conducted regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of processing before the occurrence of the personal data breach, and thus whether he fulfilled the obligation arising from Article 32(1)(d) of Regulation 2016/679.

In the jurisprudence, it is indicated that "(...) Regulation 2016/679 does not, however, determine how the administrator should fulfill the obligations arising from the principle of accountability contained in Article 5(2) of the aforementioned regulation; however, it indicates the necessity of accounting for compliance with the provisions, reporting their implementation, and presenting evidence demonstrating the proper performance of obligations. The principle of accountability obliges administrators to demonstrate that they have taken all measures aimed at ensuring compliance with the obligation to protect personal data. In light of the aforementioned principle, it is the administrator, not the supervisory authority dealing with the protection of personal data, who is responsible for developing, updating, and maintaining all procedures and documents related to the protection of personal data, as well as for creating evidential possibilities demonstrating compliance of processing with the regulations (...)" (judgment of the Provincial Administrative Court in Warsaw of February 1, 2022, case no. II SA/Wa 2106/21, LEX no. 3392761). The above is confirmed by the ruling of the Provincial Administrative Court in Warsaw of February 10, 2021, case no. II SA/Wa 2378/20: "The principle of accountability is therefore based on the legal responsibility of the administrator for properly fulfilling obligations and imposes on him the obligation to demonstrate both to the supervisory authority and to the data subject evidence of compliance with all principles of data processing." Similarly, the issue of

the principle of accountability is interpreted by the Provincial Administrative Court in Warsaw in the judgment of August 26, 2020, case no. II SA/Wa 2826/19: "Considering the entirety of the norms of Regulation 2016/679, it should be emphasized that the administrator has considerable freedom in the scope of the safeguards applied; however, he is also responsible for violating the provisions on the protection of personal data. The principle of accountability directly implies that it is the data administrator who should demonstrate, and thus prove, that he complies with the provisions specified in Article 5(1) of Regulation 2016/679."

In summary, it should be reiterated that from the circumstances of the case, it follows that the Administrator before...

****Occurrence of a breach of personal data protection –**** despite the provisions of Regulation 2016/679 being in effect since May 25, 2018, adequate solutions were not implemented to prevent the possibility of violating the principle of confidentiality of personal data (Article 5(1)(f) of Regulation 2016/679) due to the materialization of threats associated with the use of portable computers outside the organization's premises, including threats related to the theft of such equipment. Consequently, the Administrator also failed to demonstrate compliance with the accountability principle in this regard (Article 5(2) of Regulation 2016/679).

From the explanations provided by the Administrator, it follows that the implementation of appropriate procedures and solutions occurred only after the occurrence of the aforementioned breach of personal data protection (see point 7 of the factual justification). It should be noted that the Provincial Administrative Court in Warsaw also expressed its opinion on this matter, which, in its judgment of January 19, 2021, reference number II SA/Wa 702/20, stated that "(...) the data administrator should adequately secure personal data against accidental loss using appropriate technical and organizational measures. Personal data should be processed in a manner that ensures their appropriate security and confidentiality, including protection against unauthorized access to them and to the equipment used for their processing, as well as against unauthorized use of such data and equipment (recital 39 of Regulation 2016/679)."

Due to the lack of application by the data administrator of adequate technical measures aimed at minimizing the risk of a breach of security of data processed using a portable computer taken outside the Administrator's organization, it must be stated that the Administrator did not ensure an appropriate level of security for the data processed using it. This confirms the failure of the administrator to implement appropriate technical measures during the processing of personal data to ensure that this processing was carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for processing, which he was obliged to do under Article 24(1) and Article 25(1) of Regulation 2016/679, as well as the failure to apply technical measures ensuring a level of security corresponding to the risk of infringement of the rights or freedoms of natural persons by ensuring the ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services, which the data administrator is obliged to do under Article 32(1)(b) of Regulation 2016/679, taking into account the risks associated with the processing of personal data referred to in Article 32(2) of Regulation 2016/679, and consequently also the violation of the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679, which the aforementioned provisions detail. The consequence of the Administrator's breach of the principle of confidentiality is the violation of the accountability principle referred to in Article 5(2) of Regulation 2016/679.

Based on Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a) - (h) and (j) of this Regulation, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the factual findings, the President of the Personal Data Protection Office, exercising the authority granted to him under the aforementioned provision of Regulation 2016/679, determined that in the case at hand, there were grounds justifying the imposition of an administrative fine on K.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions regarding the obligations of the administrator and the processor referred to in Articles 8, 11, 25 - 39, and 42 and 43

are subject, according to paragraph 2, to an administrative fine of up to EUR 10,000,000, and in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions regarding the fundamental principles of processing, including the conditions for consent, as referred to in Articles 5, 6, 7, and 9, are subject, according to paragraph 2, to an administrative fine of up to EUR 20,000,000, and in the case of an enterprise, up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Article 83(3) of Regulation 2016/679 states that if the administrator or processor intentionally or unintentionally violates several provisions of this Regulation within the same or related processing operations, the total amount of the administrative fine shall not exceed the amount of the fine for the most serious violation.

In this case, the administrative fine imposed on the Administrator was for the violation of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, it was based on Article 83(5)(a) of this Regulation. At the same time, the fine imposed on the Administrator for the violation of all the above provisions – in accordance with Article 83(3) of Regulation 2016/679 – does not exceed the amount of the fine for the most serious violation identified in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which in accordance with Article 83...
the affected individuals.”

4. The number of affected individuals (art. 83 sec. 2 lit. h of Regulation 2016/679). The breach involved the personal data of (...) individuals. This significant number of affected individuals increases the severity of the breach, as it indicates a wider impact on the rights and freedoms of data subjects. The potential for harm is amplified when a large number of individuals are involved, as it raises concerns about the scale of the violation and the potential consequences for those individuals.

5. The degree of cooperation with the supervisory authority (art. 83 sec. 2 lit. i of Regulation 2016/679). The Administrator's level of cooperation with the President of the Personal Data Protection Office (UODO) during the investigation was taken into account. While the Administrator did provide some information, the overall cooperation was deemed insufficient, particularly in light of the seriousness of the breach. Effective cooperation with the supervisory authority is crucial in mitigating the consequences of a breach and demonstrating accountability.

6. The categories of recipients to whom the personal data have been disclosed (art. 83 sec. 2 lit. j of Regulation 2016/679). The breach resulted in unauthorized access to personal data, which may have been disclosed to third parties. The potential for such disclosure raises concerns about the misuse of the data and the subsequent risks to the affected individuals. The nature of the recipients and the context of the disclosure are important factors in assessing the impact of the breach.

7. The manner in which the breach became known to the Administrator (art. 83 sec. 2 lit. k of Regulation 2016/679). The breach was identified by the Administrator on (...) May 2022, but it is important to note that the breach had been ongoing since 25 May 2018. The delay in recognizing the breach and taking appropriate action is a significant factor in the assessment of the Administrator's accountability and the resulting administrative fine.

In conclusion, the President of UODO, taking into account the aforementioned circumstances, determined that the imposition of an administrative fine was necessary and justified in this case. The severity of the breach, the number of affected individuals, the potential for harm, and the Administrator's level of cooperation with the supervisory authority all contributed to the decision to impose a fine. The amount of the fine was set in accordance with the provisions of Regulation 2016/679, reflecting the seriousness of the violation and the need to ensure compliance with data protection regulations.

"data subjects." It should be noted that the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing, among other things, the date of birth and gender designation, is therefore closely linked to the private sphere of the individual and is also subject, as a national identification number, to special protection under Article 87 of Regulation 2016/679. It is data of a special nature and requires such special protection.

4. The degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). It should be noted that during the ongoing explanatory proceedings and subsequently the administrative proceedings, the Administrator did not undertake and did not maintain good cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects. The President of UODO requested the Administrator to provide specific explanations necessary to establish the factual state, also for the purpose of potentially exercising the powers provided for in Article 58(2)(d) of Regulation 2016/679, i.e., the power to order the administrator or processor to bring processing operations into compliance with the provisions of this regulation, and, where appropriate, to indicate the manner and deadline. For example, in a letter dated (...) July 2022, the President of UODO requested the submission of a risk analysis conducted prior to the personal data breach and one performed after the breach. In response to the above, the supervisory authority received an attachment to the explanations, a file in .xls format with a meaningless name "Attachment (...)" containing two analyses (doubts regarding the reliability of these analyses have already been discussed above) without indicating which of these analyses was conducted before and which after the personal data breach. Due to the authority's doubts regarding the reliability of the aforementioned risk analyses, in a letter dated (...) March 2023, the authority again requested the date of conducting the risk analysis prior to the occurrence of the personal data breach and the date of conducting the risk analysis performed "after taking into account the control mechanisms." In response to the precisely posed question, the Administrator provided imprecise explanations, from which it was impossible to draw any conclusions that would be relevant to establishing the factual state of the case, apart from those indicating that the Administrator essentially does not know when the risk analysis was conducted, as in the letter dated (...) March 2023, he explained that "(...) both analyses in the original version were in one file, which was submitted in the letter dated (...).07.2022. The file itself has a creation date of: (...).08.2012. (...) The first analysis was conducted around mid-2020, after which the file was verified at the time of the breach (...)" (see point 8 of the factual justification).

In turn, in response to the precisely formulated request of the authority to indicate whether a procedure regarding the processing of personal data outside the administrator's premises has been developed and implemented, and if so, whether it has been updated after the personal data breach (a request was made to provide the procedure in the version applicable before the breach and after the occurrence of the breach), the Administrator did not provide a specific answer (see point 3 of the factual justification), while providing a whole range of information and attachments to the letter dated (...) July 2012, which the authority did not request. Moreover, a key document from the perspective of these proceedings, titled "Policy (...)," was not dated. The submitted document only indicates that it constitutes "Attachment No. 1 to Order No. ... dated June 2022." The Order itself, which introduced the amended security policy, was not provided by the Administrator – nor was a relevant explanation provided that would indicate the date of announcement and implementation of the said Order.

The actions of the Administrator described above, i.e., providing evasive answers to precisely posed questions, failing to provide properly marked documents, supplying documents irrelevant to the resolution (the submission of which the President of UODO did not request), the supervisory authority assesses as deliberate actions by the Administrator aimed at hindering the President of UODO's ability to conduct the administrative proceedings reliably, and above all, prolonging the verification process of whether the state of violation of the provisions guaranteeing the protection of personal data still persists.

It was significant from the perspective of these proceedings for the President of UODO to obtain information from the Administrator that would allow for identifying the cause of the violation of the

provisions on the protection of personal data, but also for assessing whether the state of violation of these provisions still persists and whether, therefore, the President of UODO should exercise the remedial powers specified in Article 58(2)(d) of Regulation 2016/679. For this very purpose, the authority sought to establish as precisely as possible the timeframes of the documents and solutions related to the protection of personal data in force within the Administrator's organization, particularly the risk analysis and procedures for using portable computer equipment for business purposes outside the Administrator's premises.

In the authority's assessment, the lack of proper cooperation from the Administrator with the President of UODO significantly contributed to the prolongation of the administrative proceedings itself as well as the remedial process conducted to eliminate the violation and mitigate its potential negative effects [Article 83(2)(f) of Regulation 2016/679]. In determining the amount of the administrative monetary penalty, the President of UODO did not find any mitigating circumstances."

having an impact on the reduction of the imposed fine.

Other circumstances indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified violation in this case, were deemed neutral by the President of the UODO in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

1. Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). In this case, no damage was found to have occurred on the part of the individuals affected by the violation, and therefore the Administrator was not obliged to take any actions aimed at minimizing it.

2. The degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). In the Guidelines adopted on October 3, 2017, by the Article 29 Working Party regarding the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679, it was indicated that - when considering this criterion - "the supervisory authority must answer the question of to what extent the administrator, considering the nature, purposes, or scope of the processing and in light of the obligations imposed on him by the regulation." The President of the UODO found in this case a violation by the Administrator of the provisions of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679. In his opinion, the administrator bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that would have prevented the violation of personal data protection. It is evident that in the considered context of the nature, purpose, and scope of personal data processing, the Administrator did not "do everything that could be expected of him"; thus, he did not fulfill the obligations imposed on him by Articles 25 and 32 of Regulation 2016/679. In this case, this circumstance constitutes the essence of the violation itself; it is not merely a factor influencing - either mitigating or aggravating - its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Articles 25 and 32 of Regulation 2016/679 cannot be recognized by the President of the UODO in this case as a circumstance that could additionally influence a harsher assessment of the violation and the amount of the administrative monetary penalty imposed on K.

3. Any relevant previous violations by the administrator or processor (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any previous violations of personal data protection regulations committed by the Administrator, and therefore there are no grounds for treating this circumstance as aggravating. It is the duty of every administrator to comply with the law (including personal data protection laws), so the lack of previous violations cannot be a mitigating circumstance when imposing sanctions.

4. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). The President of the UODO identified the violation as a result of a report of a personal data breach made by the Administrator. In making this report, the Administrator was merely fulfilling a legal obligation, and there are no grounds to consider this circumstance as mitigating.

According to the Guidelines on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679, WP 253, "The supervisory authority may become aware

of a violation as a result of proceedings, complaints, articles in the press, anonymous tips, or notifications by the data administrator. According to the regulation, the administrator has an obligation to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the administrator cannot be interpreted as a mitigating factor.”

5. Compliance with previously applied measures in the same case, referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Before issuing this decision, the President of the UODO did not apply any of the measures listed in Article 58(2) of Regulation 2016/679 against the Administrator in the case at hand, and therefore the administrator had no obligation to take any actions related to their application, which actions, assessed by the President of the UODO, could have had an aggravating or mitigating effect on the assessment of the identified violation.

6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Administrator does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not - as stated in the provisions of Regulation 2016/679 - mandatory for administrators and processors, and therefore the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments could be taken into account in favor of the Administrator, as measures guaranteeing a higher than standard level of protection for processed personal data.

7. Financial benefits obtained directly or indirectly in connection with the violation or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that

****Administrator**** in connection with the violation did not derive any financial benefits or avoid such losses. Therefore, there are no grounds to treat this circumstance as aggravating for the Administrator. The existence of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed decidedly negatively. On the other hand, the failure of the Administrator to achieve such benefits, as a natural state independent of the violation and its consequences, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" - that occurred on the part of the entity committing the violation.

8. ****Other aggravating or mitigating factors**** (Article 83(2)(k) of Regulation 2016/679). The President of the Personal Data Protection Office, comprehensively considering the case, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the imposed administrative fine. Taking into account all the circumstances discussed above, the President of the Personal Data Protection Office concluded that the imposition of an administrative fine on the Administrator is necessary and justified by the weight, nature, and scope of the violations attributed to the Administrator. It should be stated that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679, particularly limiting to a warning (Article 58(2)(b) of Regulation 2016/679), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the Administrator would not commit further negligence in the future.

Referring to the amount of the administrative fine imposed on K., it should be noted that in the established circumstances of this case – i.e., due to the identification of violations of several provisions of Regulation 2016/679, namely the principle of data confidentiality, expressed in Article 5(1)(f) of Regulation 2016/679, and reflected in the form of obligations specified in Article 25(1), Article 32(1), Article 32(2) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679 (the principle of accountability) and the fact that the Administrator is an entity of the public finance sector – Article 102 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781) applies, which results in a limitation of the amount (to 100,000 PLN) of the administrative fine that can be imposed on an entity of the public finance sector.

In the opinion of the President of the Personal Data Protection Office, the imposed administrative fine

fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it will be effective, proportional, and deterrent in this individual case. According to the President of the Personal Data Protection Office, the fine imposed on the Administrator will be effective, as it will lead to a state in which the Administrator will implement such technical and organizational measures that ensure the processed data a level of security corresponding to the risk of violation of the rights and freedoms of the data subjects and the severity of the threats associated with the processes of processing such personal data. The effectiveness of the fine is thus equivalent to the guarantee that the Administrator, from the moment of the conclusion of this proceeding, will approach the requirements set by the provisions on the protection of personal data with the utmost diligence.

The imposed administrative fine is also proportional to the identified violation, especially its weight, effect, the circle of affected individuals, and the high risk of negative consequences that may arise in connection with the violation. In the opinion of the President of the Personal Data Protection Office, the administrative fine imposed on K. will not constitute an excessive burden for him. The amount of the fine has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of violation of the Administrator's obligations, while on the other hand, does not lead to a situation where the necessity to pay it would result in negative consequences in the form of a significant deterioration of the Administrator's financial situation. In the opinion of the President of the Personal Data Protection Office, the Administrator should and is able to bear the consequences of his negligence in the field of data protection, hence the imposition of a fine in the amount of 15,000 PLN (fifteen thousand zlotys) is fully justified.

In the opinion of the President of the Personal Data Protection Office, the administrative fine will serve, in these specific circumstances, a repressive function, as it will respond to the violation by the Administrator of the provisions of Regulation 2016/679, but also a preventive function, as it will contribute to preventing future violations of the Administrator's obligations arising from the provisions on the protection of personal data. In the opinion of the President of the Personal Data Protection Office, the imposed fine meets, in the established circumstances of this case, the criteria referred to in Article 83(1) of Regulation 2016/679, due to the weight of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679 - especially the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679.

The purpose of the imposed fine is to ensure that the Administrator complies with the provisions of Regulation 2016/679 in the future. In this factual and legal state, the President of the Personal Data Protection Office ruled as in the operative part.

****Print Article****

****Metadata****

****Entity providing the information:**** Department of Control and Violations

****Information created by:**** Jan Nowak

****Date:**** 2023-07-18

****Information entered by:**** Wioletta Golańska

****Date:**** 2023-08-09 09:05:08

****Last modified by:**** Edyta Madziar

****Date:**** 2023-10-03 09:55:54